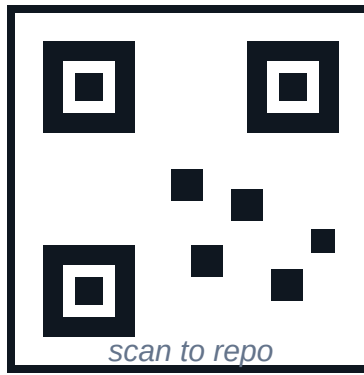


Reproducible Regression Harness for Machine-Learning Security Tools



Contract-Validated Adapters Catching Cross-Repo Breakage Before It Ships

Pooja Kiran

Security Engineering • AI / Agent Security • Cloud Security

MIT • Python 3.12 • HEAD 78b4667 • verified 2026-09-26

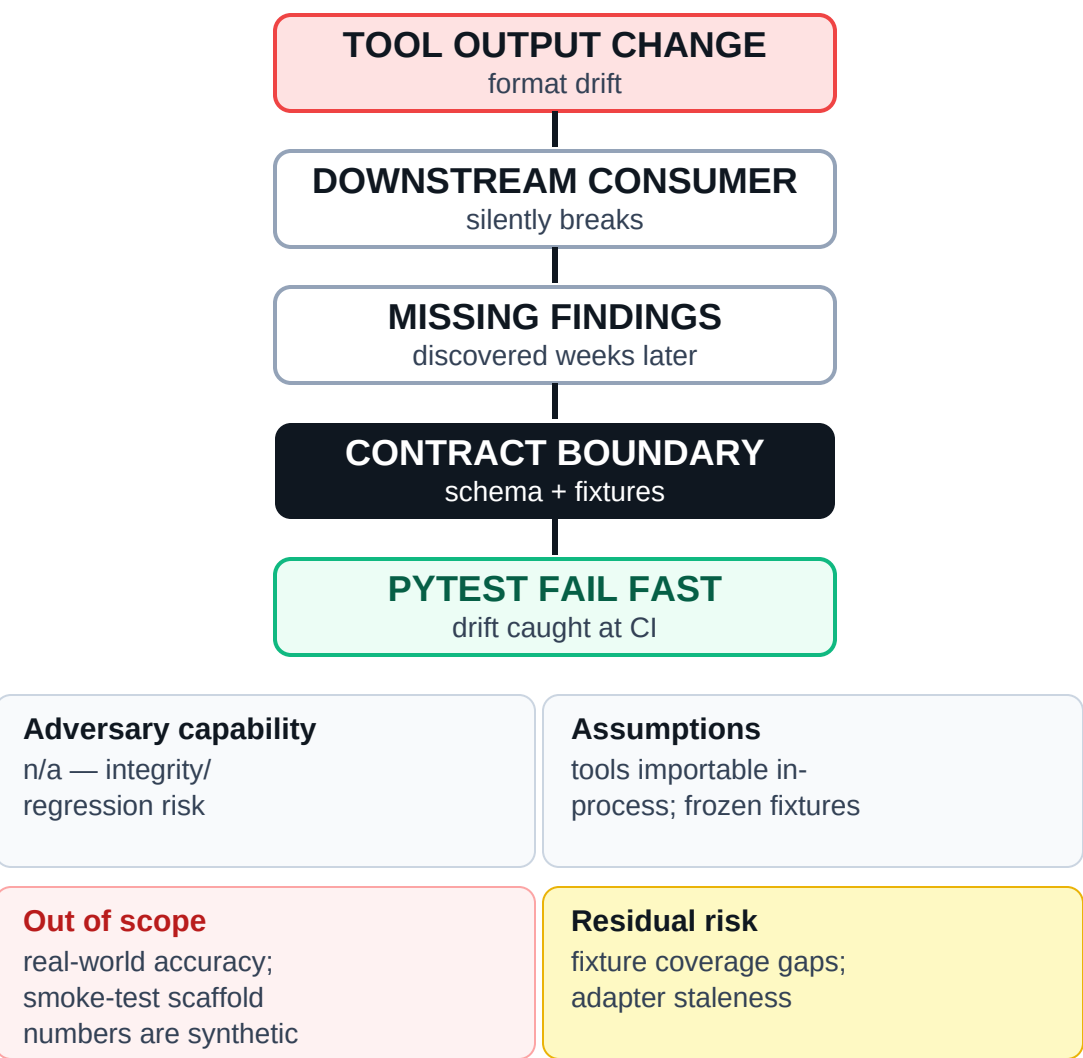
RESEARCH QUESTION

Can independently-developed ML security tools be held to shared output contracts so cross-repo format drift fails fast instead of silently?

01 • THE FAILURE MODE

Several ML security tools live in separate repos. Each passes its own tests in isolation. When one changes its output format, downstream consumers break silently — missing findings surface weeks later. A shared harness with typed adapters and JSON-schema contracts turns silent drift into an immediate failure.

02 • THREAT MODEL

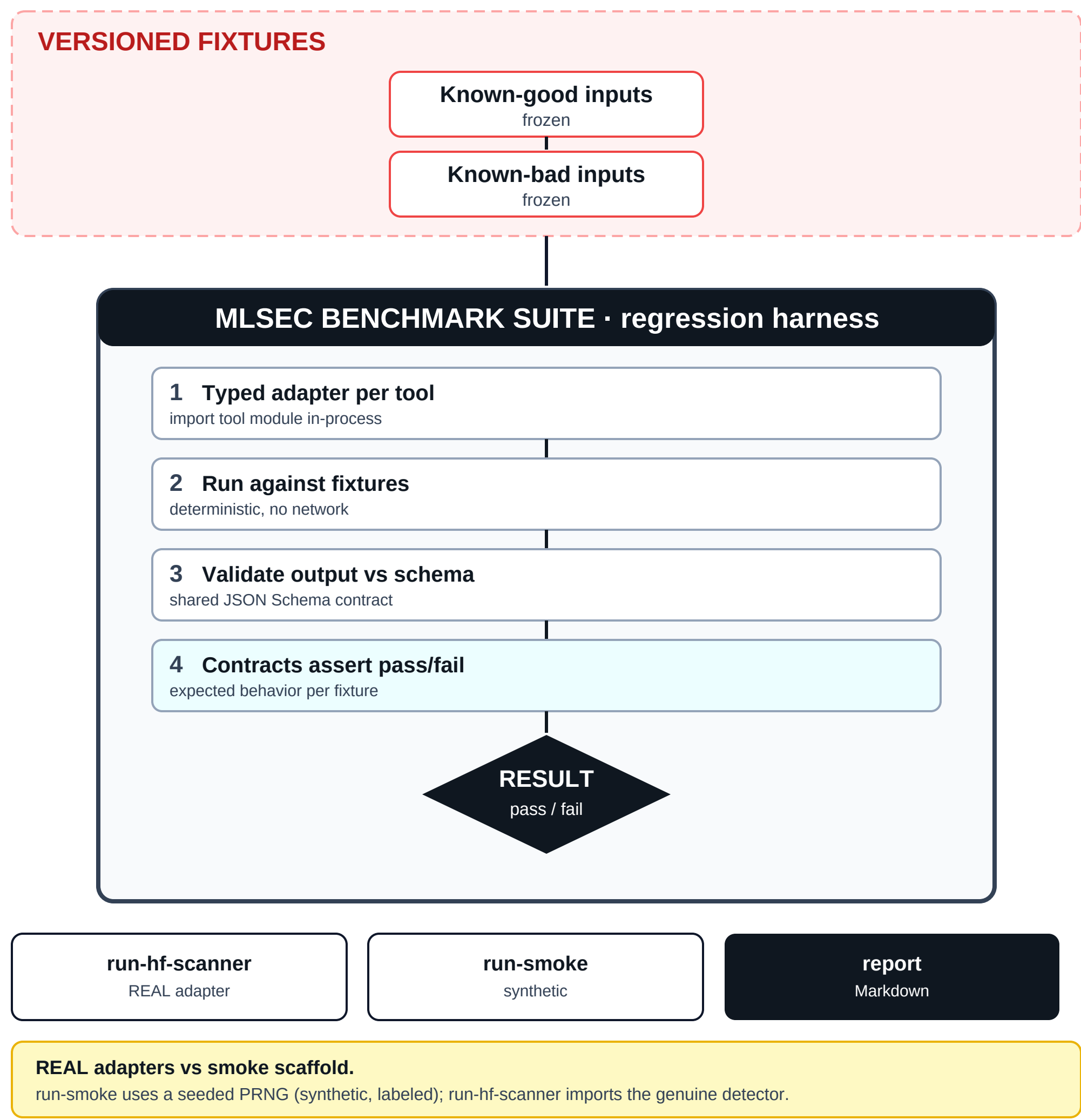


03 • OBJECTIVE

Determine whether typed adapters + JSON-schema contracts over frozen fixtures can catch cross-repo output drift in a single pytest run.

- 01 – In-process typed adapters
- 02 – Versioned known-good/bad fixtures
- 03 – JSON-schema output validation
- 04 – Real adapter gating in CI

HERO • CONTRACT-VALIDATED HARNESS



RESULTS • REAL ADAPTER (verified)

1.00

HF-SCANNER F1

3/0

TP / FP

run-hf-scanner: precision=recall=F1=1.0 on 5 committed fixtures. 3 known-bad flagged (HFS-024), 2 known-good clean. No mock.

Verified surface	
Test functions	70
Real fixtures	5
Real adapters	gated CI

REAL HF-SCANNER FIXTURE OUTCOME

Known-bad flagged	100%
Known-good clean	100%
Smoke scaffold (synthetic)	50%

Real adapter is end-to-end (no mock). Smoke bar marks synthetic plumbing, not a measure of accuracy.

EVIDENCE SEPARATION

run-hf-scanner imports the genuine scanner and reports actual findings. run-smoke's per-category numbers are seeded-PRNG synthetic, labeled as such.

NOT ESTABLISHED BY THIS REPO

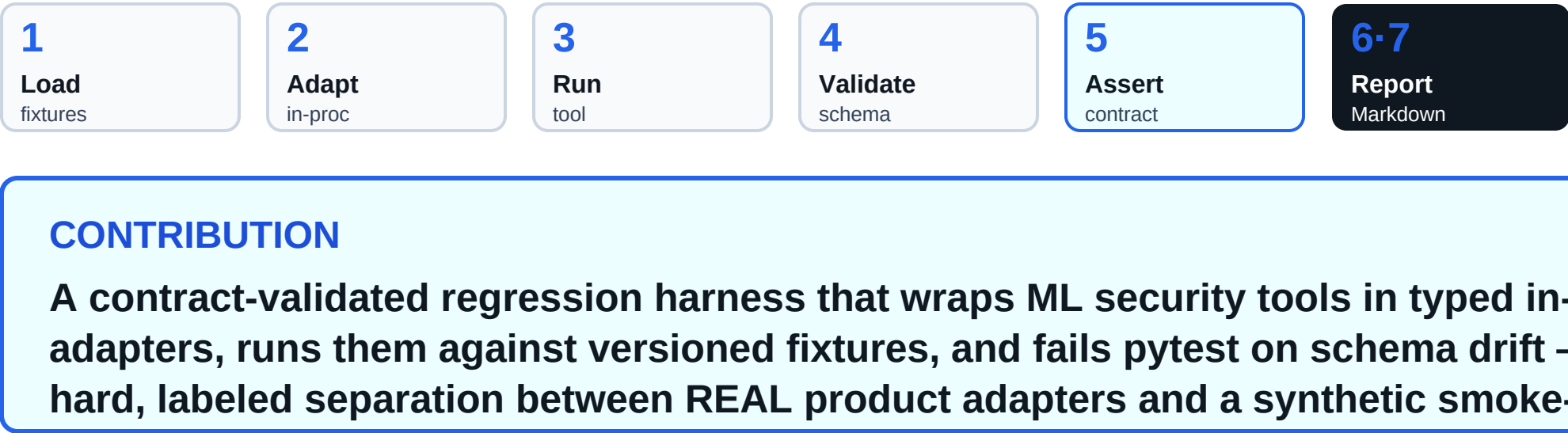
Real-world accuracy of any wrapped tool. That smoke-scaffold numbers mean anything beyond schema plumbing.

SECURITY BOUNDARY

PROTECTS / DETECTS • output-format drift • contract violations • schema regressions • real adapter gating • cross-repo breakage	DOES NOT ESTABLISH • tool accuracy • real-world rates • attack detection • smoke = synthetic • fixture completeness
--	--

Figure 1. Typed adapters run tools in-process against frozen fixtures and validate outputs against a shared schema.

METHOD • REGRESSION RUN



CONTRACTS, NOT VIBES

LIMITATIONS

- 1. Validates contracts/format, not real-world accuracy.
- 2. run-smoke numbers are synthetic (seeded PRNG).
- 3. Fixture coverage is finite; gaps possible.
- 4. Adapters can go stale if a tool changes internals.
- 5. Real adapter gating requires sibling install.

FUTURE WORK

- More REAL adapters (iam-lint, spectral, injection).
- Expanded fixture corpora per tool.
- Cross-tool pipeline contracts.
- Signed evidence provenance chain.
- Coverage reporting per adapter.

CONCLUSION

The suite holds independently-built ML security tools to shared output contracts, failing pytest on drift. Its real HF-scanner adapter verifies genuine detection end-to-end; its smoke scaffold is clearly labeled synthetic. It tests plumbing and contracts.

REPRODUCE

```
mlsec-benchmark run-hf-scanner --output r.json
pytest tests/
```